Lab Writeups

Path Traversal

PortSwigger Web Security Academy — Lab Solutions

Prepared by
Youssef Reda

Contents

Lab: File Path Traversal, Simple Case **1**

Lab: File Path Traversal, Traversal Sequences Blocked with Absolute Path Bypass **1**

Lab: File Path Traversal, Traversal Sequences Stripped Non-recursively **1**

Lab: File Path Traversal, Traversal Sequences Stripped with Superfluous URL-decode **1**

Lab: File Path Traversal, Validation of Start of Path **2**

Lab: File Path Traversal, Validation of File Extension with Null Byte Bypass **2**

Lab: File Path Traversal, Simple Case

1. Use Burp Suite to intercept a request that fetches a product image.
2. Modify the `filename` parameter to the following payload:

```
../../../etc/passwd
```

3. Forward the modified request and inspect the response. The contents of `/etc/passwd` should be returned, solving the lab.

Lab: File Path Traversal, Traversal Sequences Blocked with Absolute Path Bypass

1. Use Burp Suite to intercept a request that fetches a product image.
2. Modify the `filename` parameter to the absolute path:

```
/etc/passwd
```

3. Forward the modified request and inspect the response. The contents of `/etc/passwd` should be returned, solving the lab.

Lab: File Path Traversal, Traversal Sequences Stripped Non-recursively

1. Use Burp Suite to intercept a request that fetches a product image.
2. Modify the `filename` parameter using the following payload to bypass the non-recursive traversal filter:

```
....//....//....//etc/passwd
```

3. Forward the modified request and inspect the response. The contents of `/etc/passwd` should be returned, solving the lab.

Lab: File Path Traversal, Traversal Sequences Stripped with Superfluous URL-decode

1. Use Burp Suite to intercept a request that fetches a product image.
2. Modify the `filename` parameter using the following double URL-encoded payload:

```
..%252f..%252f..%252fetc/passwd
```

3. Forward the modified request and inspect the response. The contents of `/etc/passwd` should be returned, solving the lab.

Lab: File Path Traversal, Validation of Start of Path

1. Use Burp Suite to intercept a request that fetches a product image.
2. Modify the `filename` parameter to include the expected base directory followed by traversal sequences:

```
/var/www/images/../../../etc/passwd
```

3. Forward the modified request and inspect the response. The contents of `/etc/passwd` should be returned, solving the lab.

Lab: File Path Traversal, Validation of File Extension with Null Byte Bypass

1. Use Burp Suite to intercept a request that fetches a product image.
2. Modify the `filename` parameter using the following payload to bypass the file extension validation:

```
../../../etc/passwd%00.png
```

3. Forward the modified request and inspect the response. The contents of `/etc/passwd` should be returned, solving the lab.